

| Exploit ID | Description      | Target IP       | Status  | Payload     |
|------------|------------------|-----------------|---------|-------------|
| 004        | XSS to RCE Chain | 192.168.132.129 | Success | Meterpreter |

## Customization: Python PoC Modification

The original Exploit-DB Python proof-of-concept for **CVE-2021-22205** was enhanced to support dynamic target URLs and configurable reverse shell parameters. Stability improvements included refined error handling and optimized HTTP request headers. Payload execution was validated in a controlled laboratory environment, ensuring consistent command execution without modifying the underlying exploit logic.

---

## Exploit Chain Description

A successful chained attack was simulated against host **192.168.132.129**, beginning with a stored **Cross-Site Scripting (XSS)** vulnerability and escalating to **Remote Code Execution (RCE)**. The attack leveraged **CVE-2021-22205**, resulting in a successful Meterpreter session and confirming full system compromise within a controlled **Metasploitable2** lab environment.

---

## Remediation Recommendations

- Sanitize and validate all user-supplied input
  - Implement proper output encoding to mitigate XSS vulnerabilities
  - Update and patch GitLab to remediate **CVE-2021-22205**
  - Restrict file upload functionality and execution permissions
  - Perform regular vulnerability scanning and enforce patch management practices
-

Dear Development Team,

During a recent security assessment, a critical exploit chain was identified on the web server (192.168.132.129). A stored Cross-Site Scripting (XSS) vulnerability was successfully leveraged to escalate privileges and exploit CVE-2021-22205, resulting in remote code execution and the establishment of a Meterpreter session.

This confirms full system compromise under controlled laboratory conditions. Immediate remediation is strongly recommended, including strict input validation, proper output encoding, and updating GitLab to the latest patched version. Additionally, we advise reviewing file upload controls and conducting a follow-up security scan once corrective measures are implemented.

Please let us know if further clarification or assistance is required.

Regards,  
Shaun Franklyn